The Legacy Server Breach

Incident Response Report — Tech Solutions Inc. Security Operations Center

Project	Cybersecurity capstone — SOC incident response simulation
Target system	legacyserver — 192.168.56.101 (Ubuntu 8.04, kernel 2.6.24)
Environment	Isolated VirtualBox lab (Kali Linux attacker + legacy Ubuntu target)
Framework	PICERL incident response lifecycle
Tools	Nmap, Wireshark, netcat, Linux CLI, iptables

Prepared with AI assistance (Claude) as the “Virtual Analyst.” Every AI-generated finding in this report was independently verified with a manual tool; verification evidence is embedded throughout and in the Evidence Appendix.

1. Executive Summary

On 2026-10-09 the Security Operations Center at Tech Solutions Inc. responded to anomalous network traffic flagged by the NOC at 08:00 from a legacy internal Ubuntu server (“legacyserver”) that supports a critical, older business application. The investigation confirmed a genuine security incident.

The server runs severely outdated software and exposes many unnecessary network services. The point of entry is an outdated file-transfer (FTP) service running a version known to contain a hidden backdoor, which lets an outside attacker take complete administrative (root) control of the server **without any password**. A second, unauthorized remote-access channel was found already open on the system — direct evidence that unauthorized access had occurred.

Business impact (rated critical): full compromise of a server supporting a critical application means an attacker could read or alter any data on it, pivot deeper into the network, and disrupt the business function it serves.

Response: I isolated the server while preserving evidence, disabled the vulnerable service, removed the unauthorized backdoor, and verified the entry point is now closed. Because this legacy server cannot be patched by normal means, I recommend compensating controls and a planned migration to a supported platform.

2. Incident Timeline

Time (2026)	Phase	Action	Evidence
Oct 9, 08:00	Detection	NOC flagged anomalous traffic from legacyserver	NOC alert
Oct 9, 13:55	Prepare	Built isolated lab (Host-Only + DHCP); confirmed connectivity; snapshots	Fig. 1
Oct 9, 14:16	Detect	Full Nmap scan (all 65,535 ports); found vsftpd 2.3.4 + port-1524 backdoor	Fig. 2
Oct 9, 14:32	Detect	Verified FTP version past masked banner; confirmed anonymous login	Fig. 3
Oct 11, 21:02	Detect	Wireshark capture — FTP credentials in cleartext	Fig. 4
Oct 11, 21:17	Contain	Preserved volatile evidence; isolated host at network layer	Fig. 5
Oct 11, 22:06	Eradicate	Gained root; disabled xinetd; removed backdoor from config	Fig. 6
Oct 11, 22:32	Recover	Re-scanned — port 21 filtered, port 1524 closed	Fig. 7
Oct 11, 22:57	Recover	Took Hardened - Post-Remediation snapshot	Fig. 8

Hands-on lab work spanned multiple sessions; the 08:00 detection is the scenario trigger.

3. Technical Findings

Methodology. A full TCP scan was run from the Kali analyst workstation: `sudo nmap -sS -sV -sC -p- -oN legacyserver_fullscan.txt 192.168.56.101`. Every tool-suggested finding was re-confirmed with a manual tool before being treated as evidence.

3.1 Attack vector — CVE-2011-2523 (vsftpd 2.3.4)

Field	Value
CVE ID	CVE-2011-2523
Service	vsftpd 2.3.4 — port 21/tcp
CVSS v2	10.0 — Critical (AV:N/AC:L/Au:N/C:C/I:C/A:C)
Type	Backdoor / remote root command execution
Anonymous login	Allowed (FTP code 230)

The vsftpd 2.3.4 source archive was compromised in 2011 and shipped with a backdoor: supplying a username containing `:)` opens an unauthenticated root shell on TCP port 6200. The connection banner here is masked (`220 Welcome to LegacyServer FTP service.`), so `nmap -sV` could only report "vsftpd 2.0.8 or later." Re-running `nmap -p21 -sV --script=ftp-anon,ftp-syst` exposed the true version through the FTP STAT response — `vsFTPd 2.3.4 - secure, fast, stable` — and confirmed anonymous login.

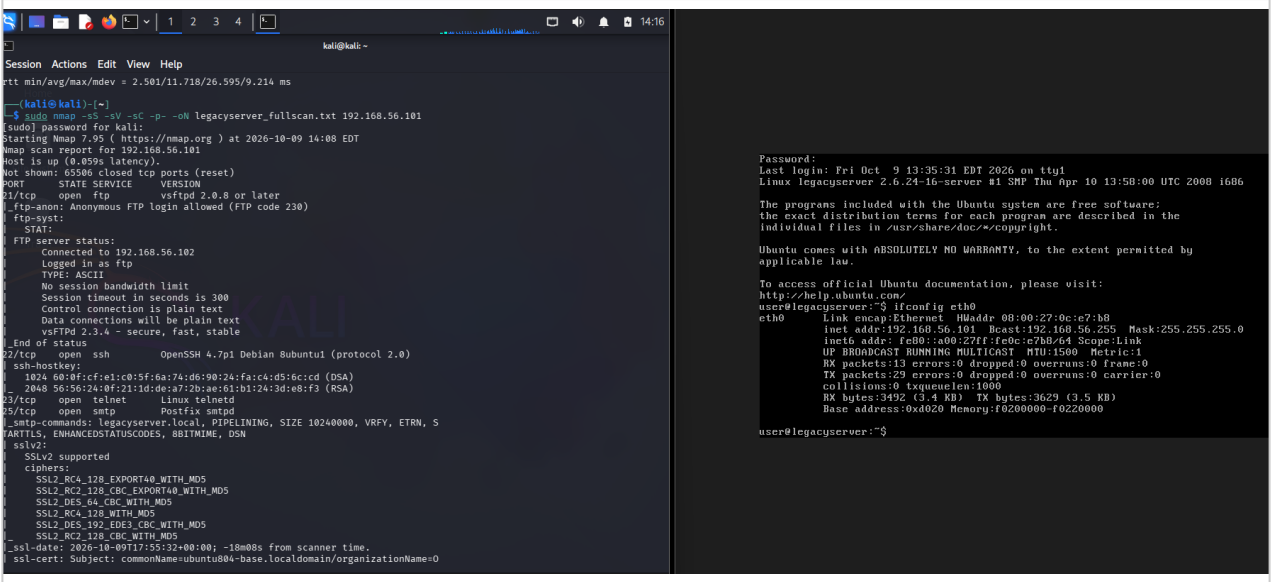


Fig. 2 — Full Nmap scan: ~25 open ports; port 21 vsftpd, anonymous FTP login allowed.

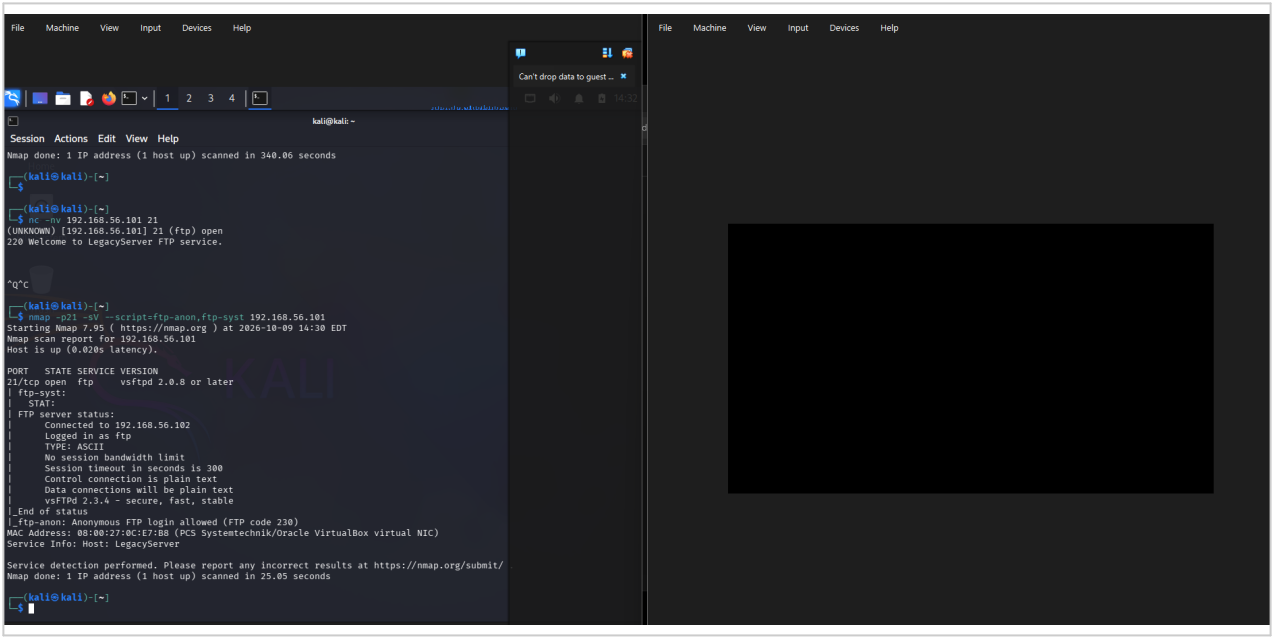


Fig. 3 — Manual verification: FTP STAT reveals vsFTPd 2.3.4 past the masked banner; anonymous login confirmed.

3.2 Evidence of compromise — open root backdoor (port 1524)

The scan found an unauthenticated root shell listening on TCP port 1524 (nmap: `bindshell Bash shell (**BACKDOOR**; root shell)`). The backdoor was defined in `/etc/inetd.conf` as `ingreslock stream tcp nowait root /bin/bash bash -i` — a root shell wired to the ingreslock port. A standing open root shell is direct evidence that unauthorized access had already occurred, corroborating the NOC alert.

3.3 Cleartext traffic (Wireshark)

FTP transmits credentials with no encryption. A live capture of an FTP login shows the username and password in plain text on the wire — readable by anyone sniffing the network.

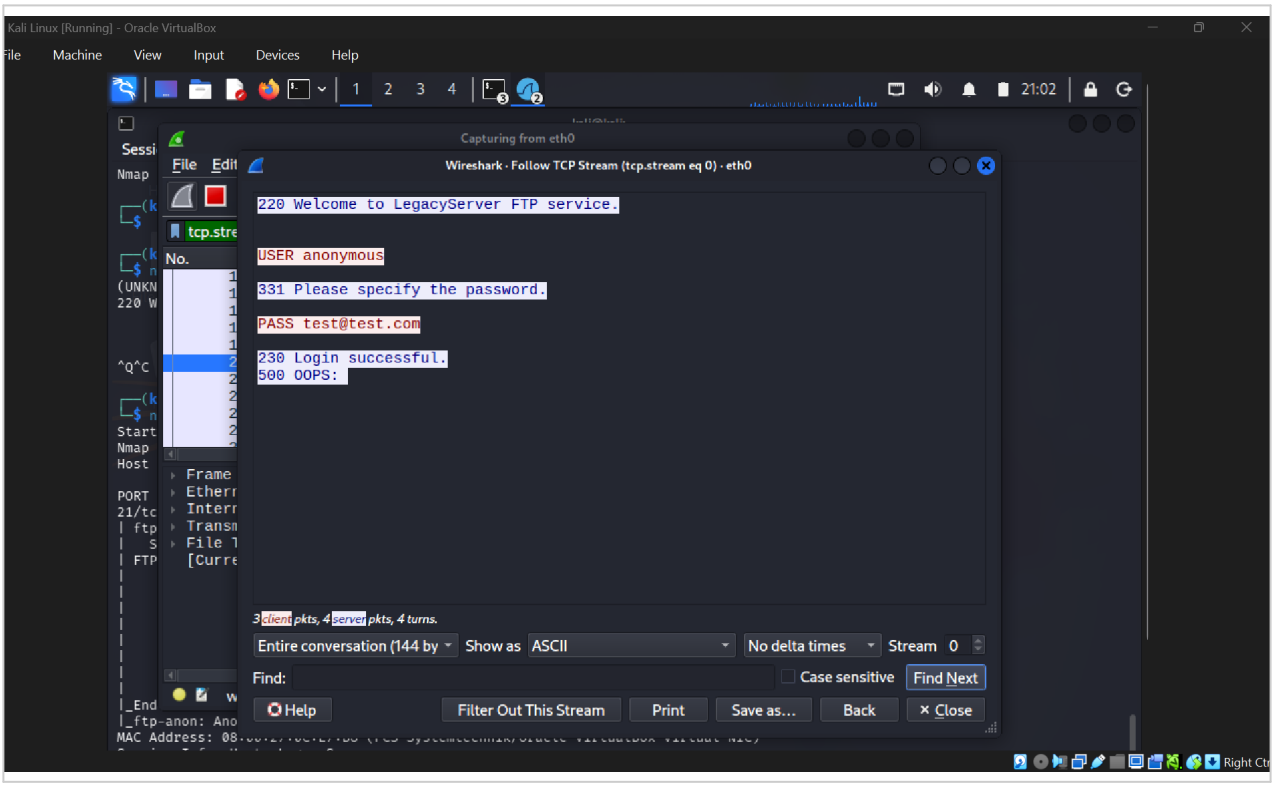


Fig. 4 — Wireshark Follow TCP Stream: FTP USER / PASS transmitted in cleartext.

3.4 Full exposed attack surface

Port(s)	Service / Version	Risk	Reference
21	vsftpd 2.3.4 (anon)	Backdoor -> root	CVE-2011-2523
1524	Bash root shell (BACKDOOR)	Open root access	Planted backdoor
139/445	Samba smbd 3.0.20	Command injection	CVE-2007-2447
6667/6697	UnrealIRCd	Backdoored -> RCE	CVE-2010-2075
3632	distccd	Remote code exec	CVE-2004-2687
23, 512-514	telnet + r-services	Cleartext / trust login	—
3306/5432/5900	MySQL / PostgreSQL / VNC	Weak default creds	—
2121	ProFTPD 1.3.1	Outdated FTP	—

4. Actions Taken

4.1 Containment — preserve evidence, then isolate

Volatile state was captured from legacyserver *before* isolation: listening ports (`netstat -tuln`), running processes (`ps auxf`), and logged-in users (`who`), saved to `/tmp`. The `who` output revealed an active root session on pts/0 alongside the `user` login. The host was then isolated at the network layer (Devices → Network → Disconnect Network Cable) with the VM left running to preserve memory, and a `Compromised - Post-Containment` snapshot was taken.

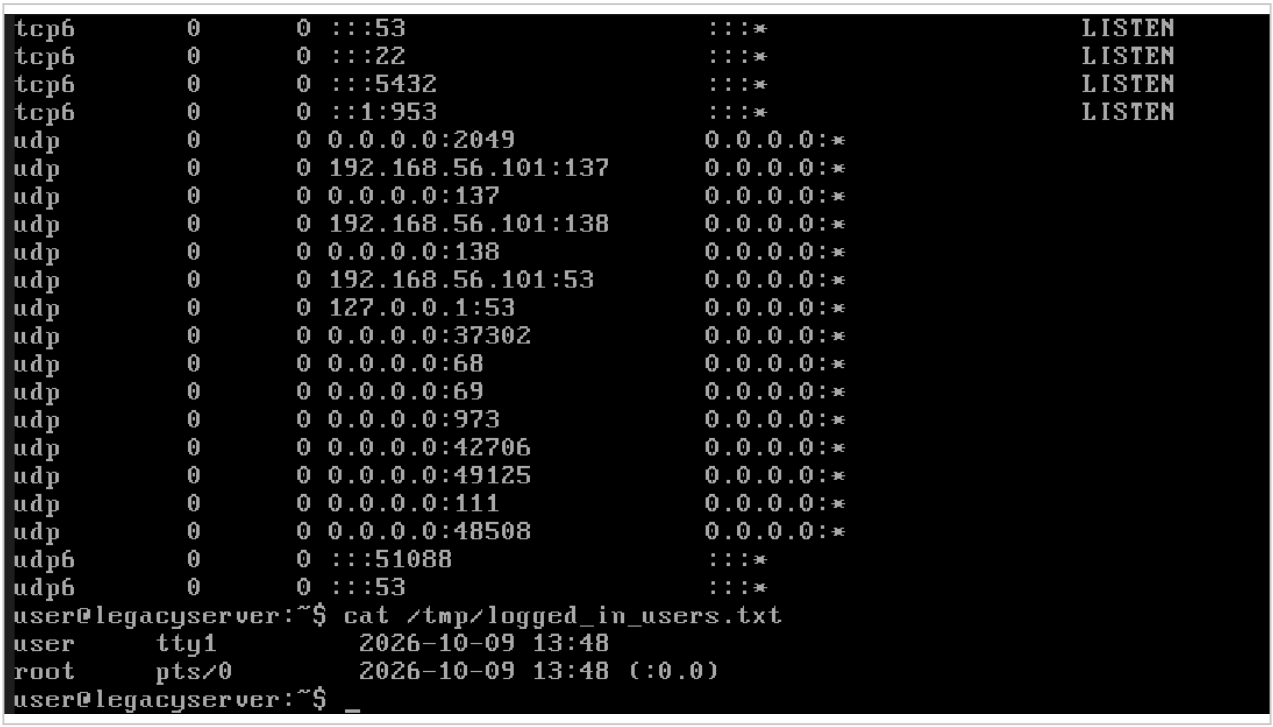


Fig. 5 — Containment: preserved listening ports and logged-in users (note the active root session).

4.2 Eradication & Recovery

Eradication required root, but the root password was unknown and `user` could not `sudo`. Under controlled, isolated conditions, the attacker's own port-1524 backdoor was used to obtain a root shell (`id` returned `uid=0(root)`), and a known root password was set via `chpasswd`.

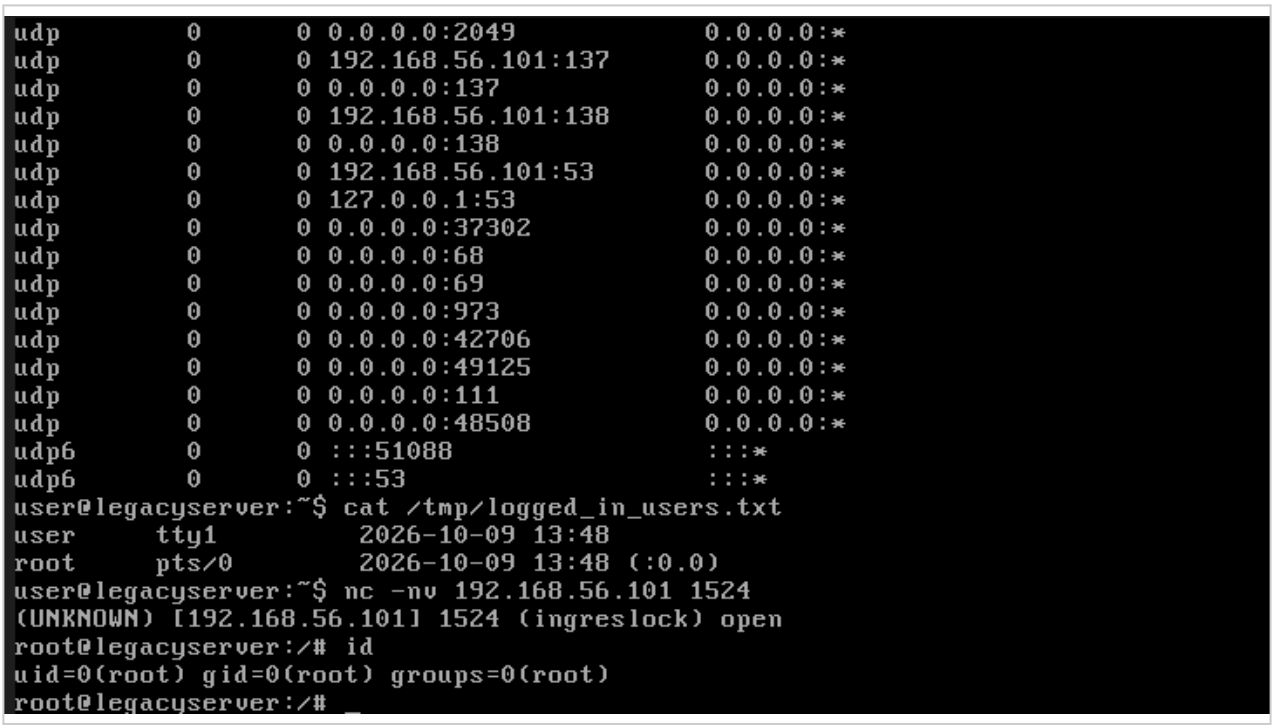


Fig. 6 — Root obtained through the port-1524 backdoor with zero authentication (uid=0).

Both the vulnerable FTP (port 21) and the backdoor (port 1524) were launched by the `xinetd` super-server, alongside only obsolete services (chargen, daytime, discard, echo, time). Remediation steps:

- `iptables -A INPUT -p tcp --dport 21 -j DROP` — firewall the FTP entry point (compensating control)
- `update-rc.d -f xinetd remove` — stop xinetd starting at boot
- `/etc/init.d/xinetd stop` — close ports 21 and 1524
- Deleted the backdoor line `ingreslock ... /bin/bash` from `/etc/inetd.conf`

Verification. From Kali, `nc 192.168.56.101 1524` now returns *Connection refused*, and `nmap -p21,1524` reports **21/tcp filtered, 1524/tcp closed** (both were `open` before). A `Hardened - Post-Remediation` snapshot was taken.

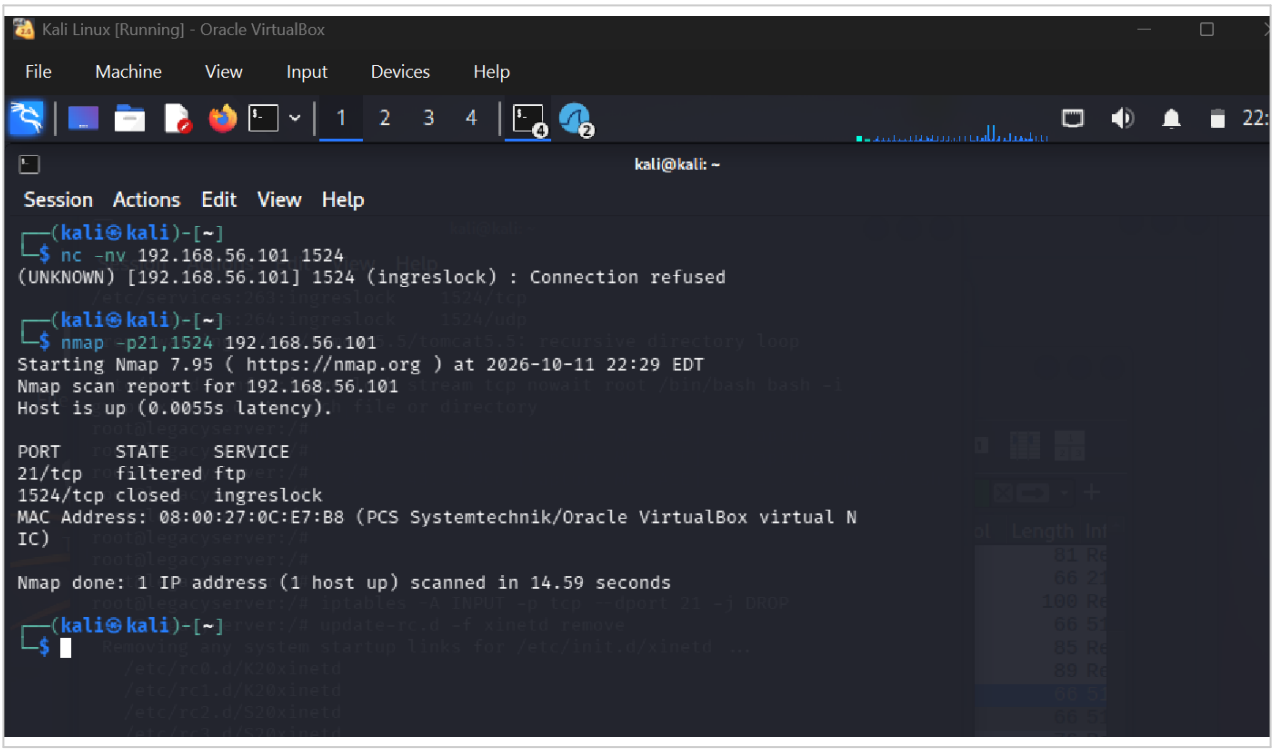


Fig. 7 — Remediation verified from Kali: port 21 filtered, port 1524 closed.

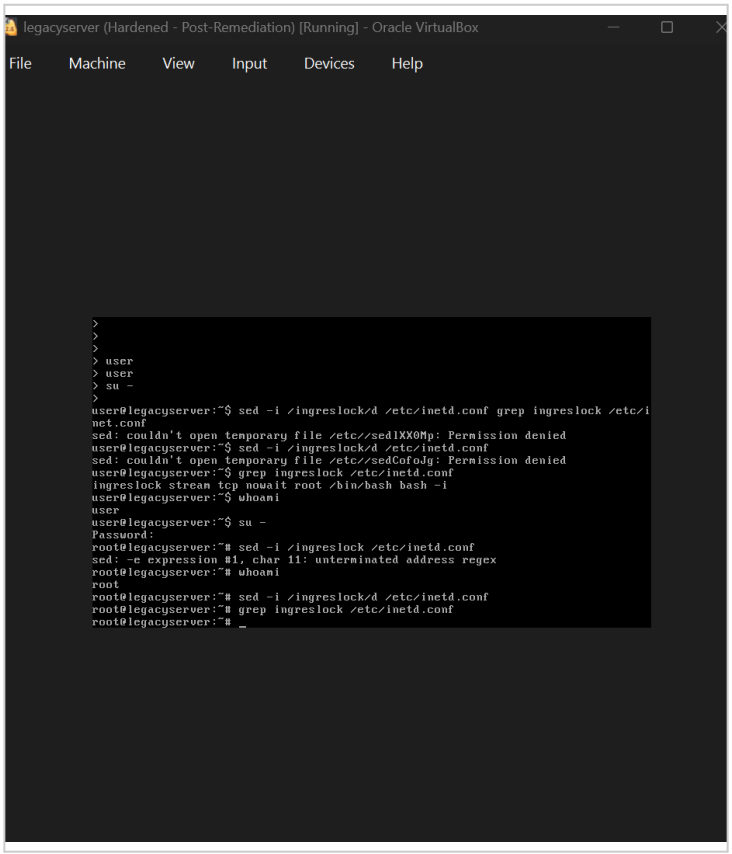


Fig. 8 — Backdoor definition deleted from /etc/inetd.conf; Hardened - Post-Remediation snapshot (see title bar).

5. Recommendations

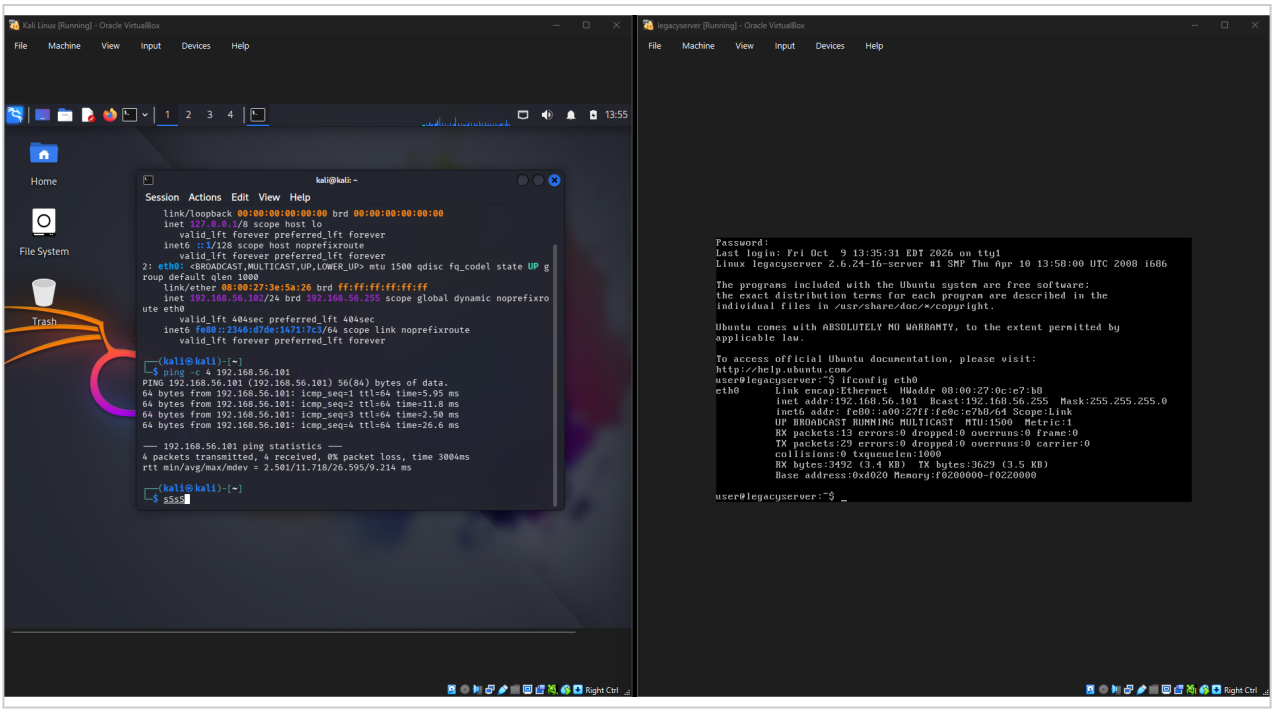
The root problem is an unpatchable, end-of-life server exposing many unnecessary services. Recommendations are ordered by priority.

- **Reduce the attack surface now.** Disable every service not required by the business application — FTP, telnet, the r-services, distcc, UnrealIRCd, NFS, VNC.
- **Apply compensating controls.** Place the server behind a firewall that permits only the specific ports the critical application needs and denies all else by default.
- **Isolate the legacy host.** Move it to a segmented network with no direct internet access and tightly restricted internal reachability.
- **Fix credential hygiene.** Disable anonymous FTP; set strong, unique passwords on MySQL, PostgreSQL, and VNC; remove default and shared accounts.
- **Add monitoring and logging.** Deploy IDS/IPS and centralized logging on this host so anomalous traffic is detected and alerted in real time.
- **Plan migration.** The only durable fix is to migrate the critical application to a supported, patched platform on a defined timeline, then decommission the legacy server.

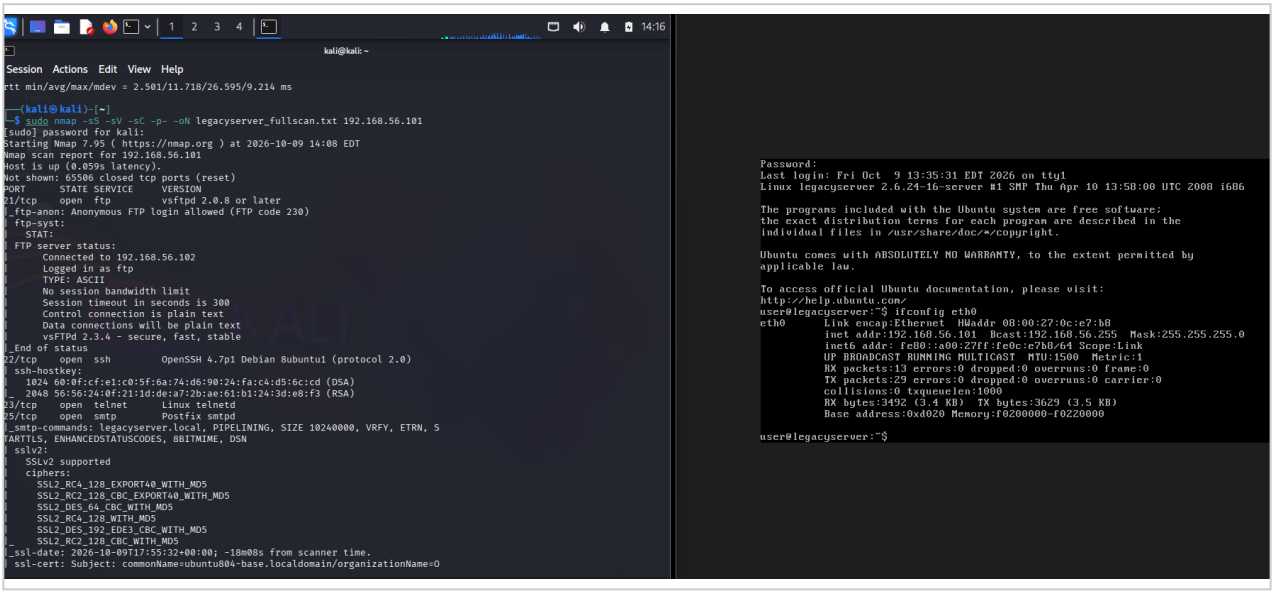
Bottom line: compensating controls and isolation reduce immediate risk, but the server remains fundamentally unsupportable — migration should be funded and scheduled as the real remediation.

6. Evidence Appendix

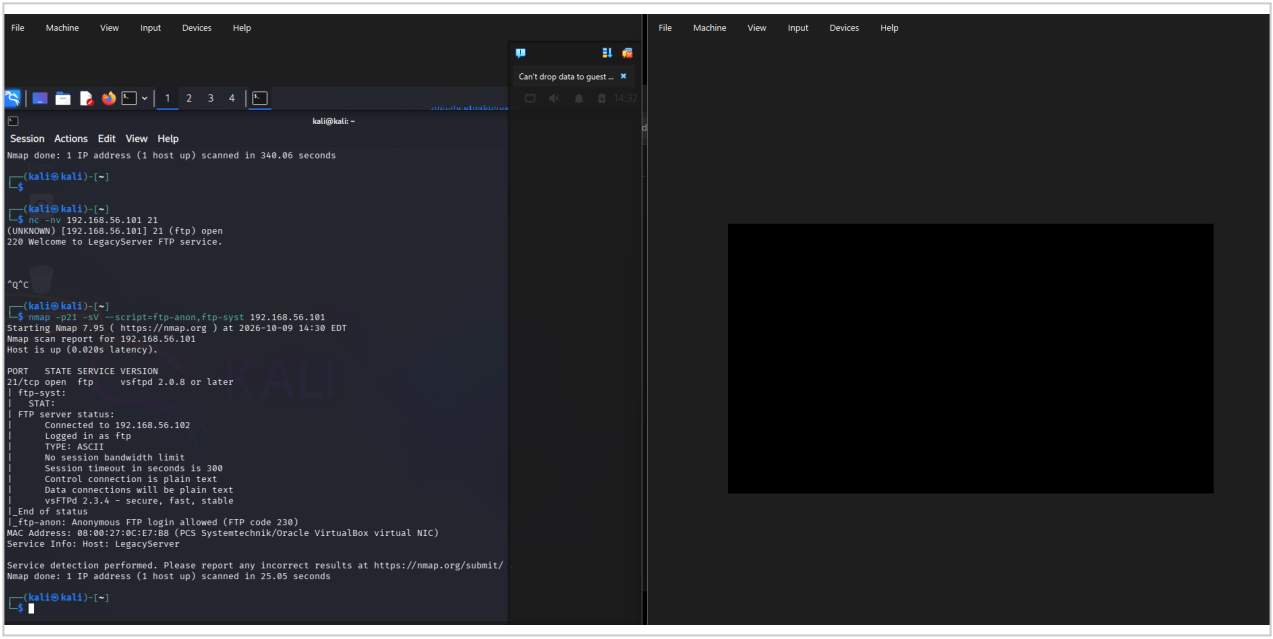
Screenshots captured during the engagement, documenting each phase of the investigation and remediation — the connectivity test, the scan, the fix, and the verification.



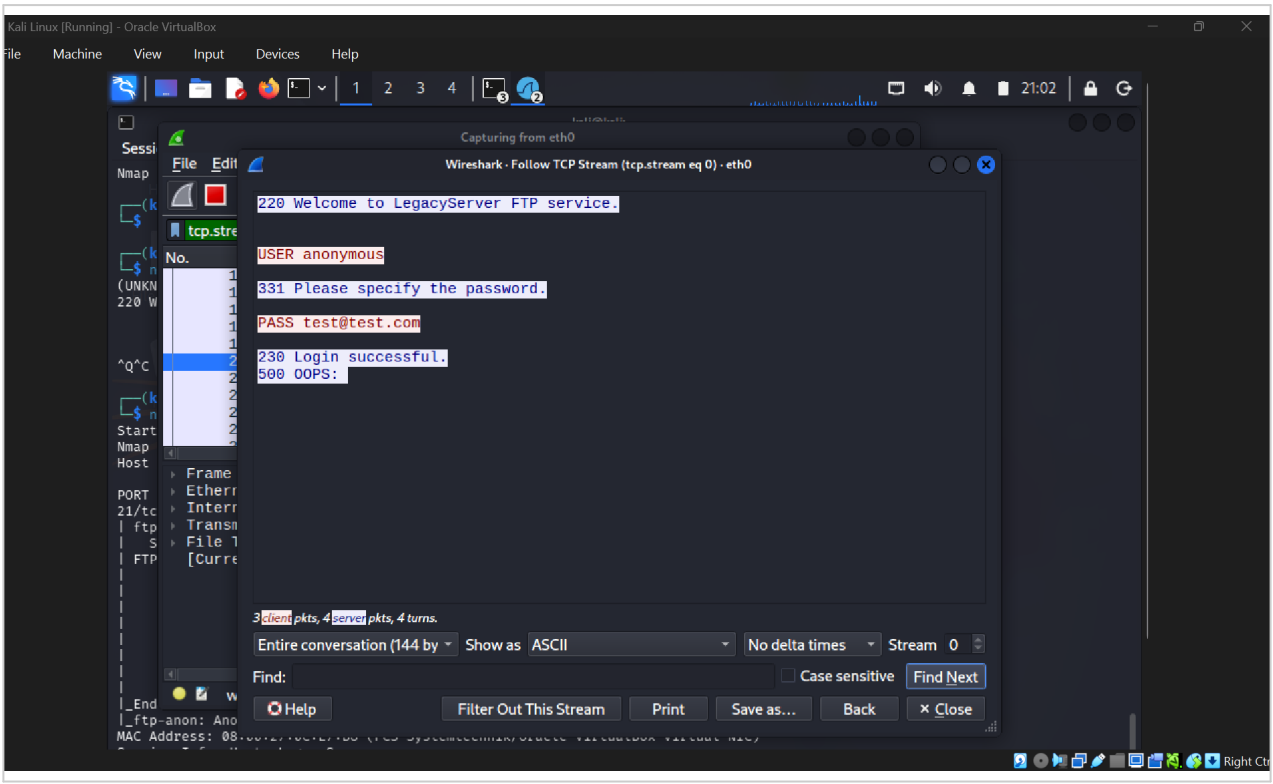
A1 — Connectivity Test: successful ping (4/4 replies) between Kali (192.168.56.102) and legacyserver (192.168.56.101).



A2 — Nmap Scan: full-port scan results (port 21 vsftpd, anonymous login allowed).



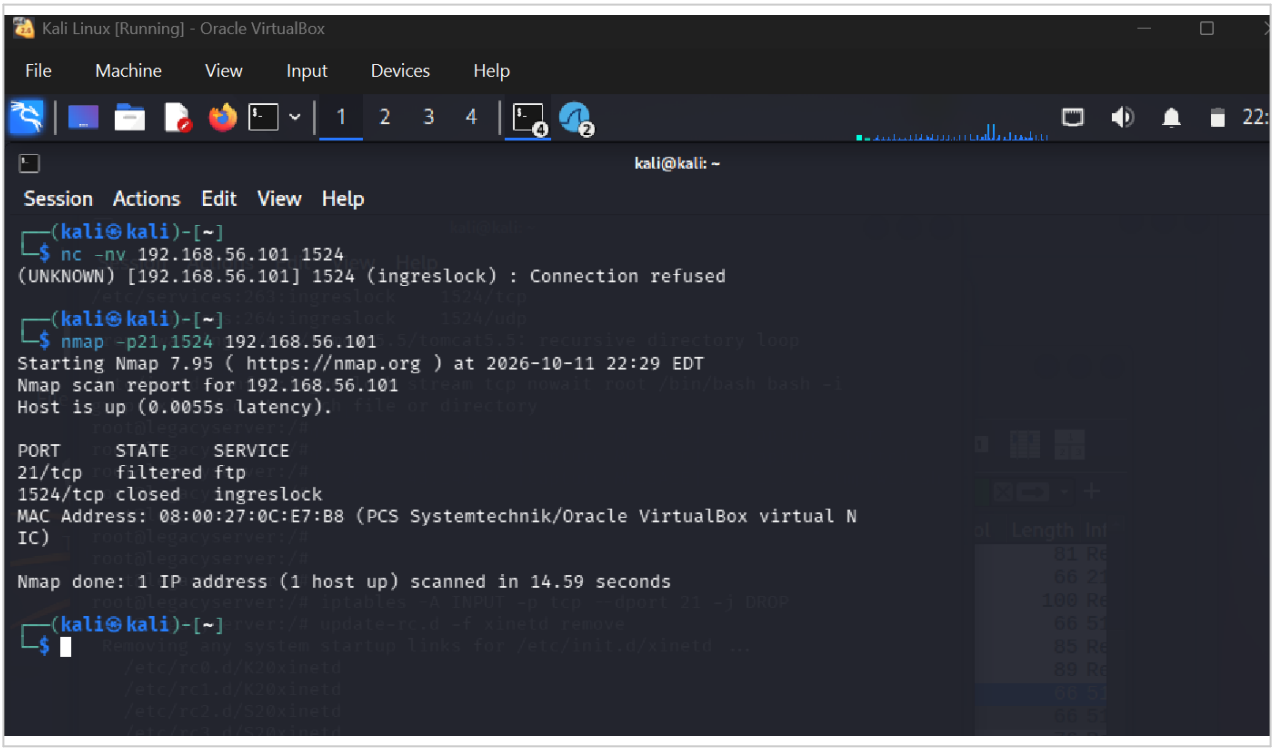
A3 — Verification: FTP STAT confirms vsFTPd 2.3.4 past the masked banner; anonymous login allowed.



A4 — Wireshark: FTP credentials captured in cleartext.

```
udp        0      0 0.0.0.0:2049            0.0.0.0:*
udp        0      0 192.168.56.101:137      0.0.0.0:*
udp        0      0 0.0.0.0:137             0.0.0.0:*
udp        0      0 192.168.56.101:138      0.0.0.0:*
udp        0      0 0.0.0.0:138             0.0.0.0:*
udp        0      0 192.168.56.101:53       0.0.0.0:*
udp        0      0 127.0.0.1:53            0.0.0.0:*
udp        0      0 0.0.0.0:37302           0.0.0.0:*
udp        0      0 0.0.0.0:68              0.0.0.0:*
udp        0      0 0.0.0.0:69              0.0.0.0:*
udp        0      0 0.0.0.0:973             0.0.0.0:*
udp        0      0 0.0.0.0:42706           0.0.0.0:*
udp        0      0 0.0.0.0:49125           0.0.0.0:*
udp        0      0 0.0.0.0:111             0.0.0.0:*
udp        0      0 0.0.0.0:48508           0.0.0.0:*
udp6       0      0 :::51088                :::*
udp6       0      0 :::53                   :::*
user@legacyserver:~$ cat /tmp/logged_in_users.txt
user     tty1         2026-10-09 13:48
root     pts/0        2026-10-09 13:48 (:0.0)
user@legacyserver:~$ nc -nv 192.168.56.101 1524
(UNKNOWN) [192.168.56.101] 1524 (ingreslock) open
root@legacyserver:/# id
uid=0(root) gid=0(root) groups=0(root)
root@legacyserver:/# _
```

A5 — The fix (part 1): root obtained through the port-1524 backdoor with no authentication (uid=0).



A6 — Remediation Verification: port 21 filtered, port 1524 closed after hardening.